

Diagrammes UML — EBIOS RM

Les six diagrammes de référence de la plateforme d'analyse de risque EBIOS RM : les acteurs, le modèle de domaine complet sur les 5 ateliers, l'architecture logicielle, le flux applicatif critique, les cycles de vie et le déploiement.

SOMMAIRE

- 01 Cas d'utilisation
- 02 Classes — modèle de domaine
- 03 Composants — architecture logicielle
- 04 Séquence — validation d'un atelier
- 05 États — cycles de vie
- 06 Déploiement

01 Diagramme de cas d'utilisation

OBJECTIF

Montrer qui fait quoi sur la plateforme, pour l'ensemble des 5 ateliers.

NIVEAU D'ABSTRACTION

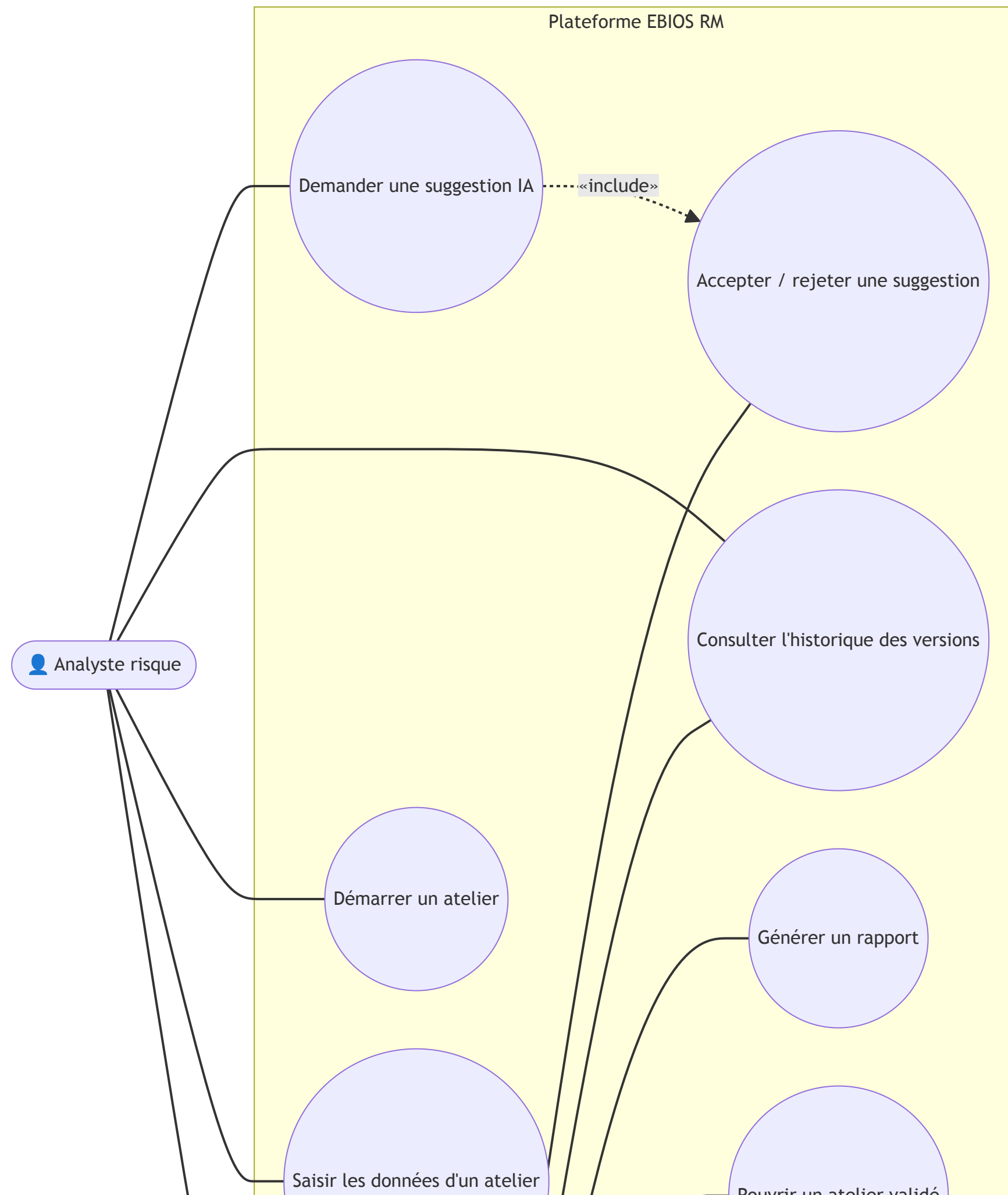
Métier — aucune notion technique.

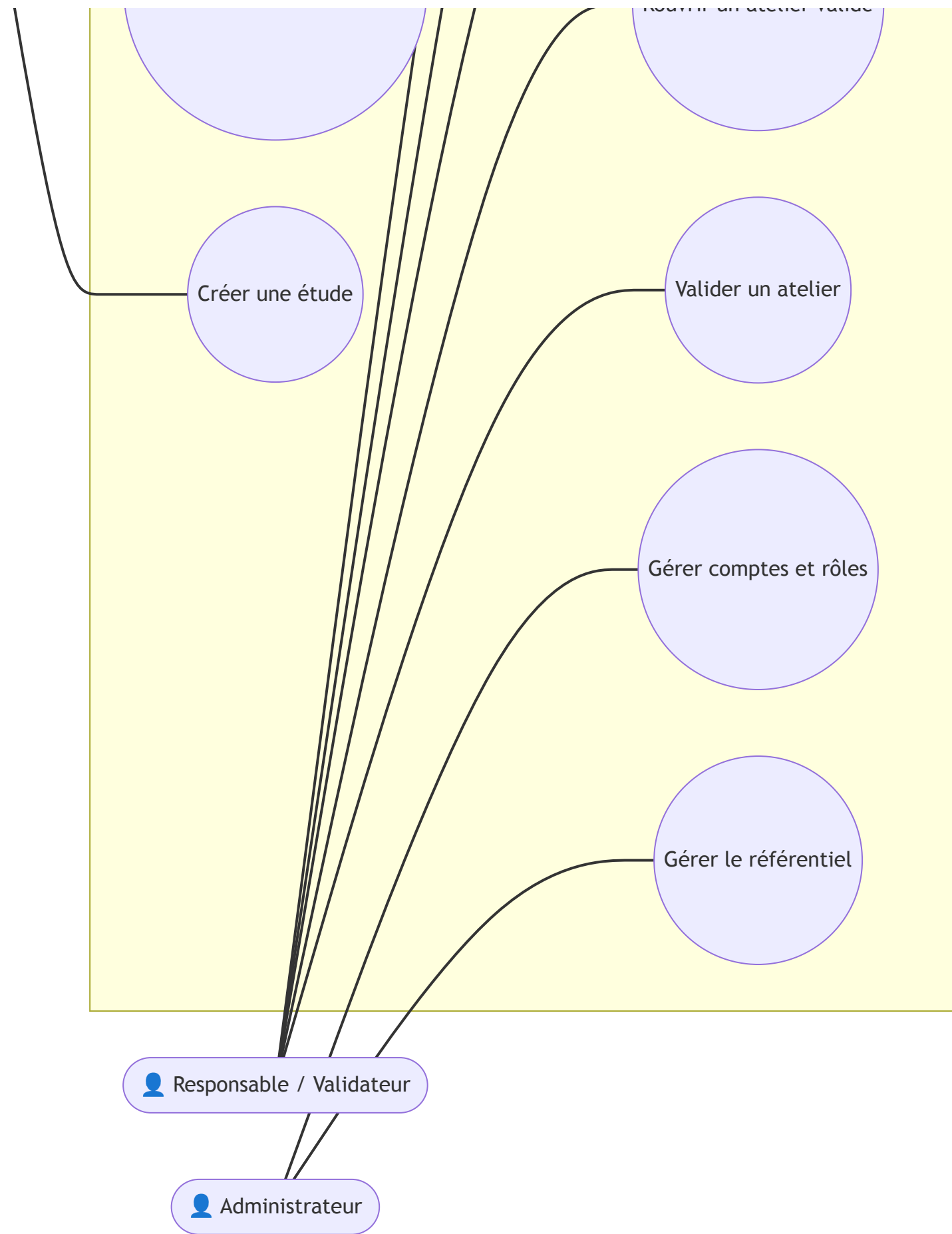
REPRÉSENTÉ

Les 3 acteurs justifiés par le métier et le RBAC ; les cas d'usage transverses aux 5 ateliers.

EXCLU VOLONTAIREMENT

Le détail atelier par atelier — chacun partage la même mécanique (saisir, démarrer, valider) ; les cas d'usage purement techniques (supervision, santé du service).





Le validateur signe la validation d'un atelier, ce qui fige automatiquement un snapshot — mais ne génère pas le rapport PDF lui-même : « Générer un rapport » reste une action séparée, à la demande, qui relit le dernier snapshot disponible (cf. diagramme de séquence). C'est volontairement *sans* lien «include» sur ce schéma. Aucun acteur « invité » ou « visiteur » : le métier EBIOS RM ne définit que ces trois rôles, correspondant à trois responsabilités distinctes — produire l'analyse, l'engager formellement, administrer la plateforme.

Ces 3 acteurs sont des rôles applicatifs (RBAC), pas les participants réels d'un atelier EBIOS RM en présentiel — la méthode réunit Direction, Métiers, RSSI, DSI et parfois un spécialiste cybersécurité selon l'atelier (documentation officielle), des rôles de réunion sans équivalent logiciel formel. La simplification à 3 rôles applicatifs est délibérée et assumée pour la plateforme.

Ces 3 acteurs sont des rôles applicatifs (RBAC), pas les participants réels d'un atelier EBIOS RM en présentiel — la documentation officielle réunit Direction, Métiers, RSSI, DSI et parfois un spécialiste cybersécurité selon l'atelier, des rôles de réunion sans équivalent logiciel formel. La simplification à 3 rôles applicatifs est délibérée et assumée pour la plateforme.

02a **Vue d'ensemble — le fil des 5 ateliers**

OBJECTIF

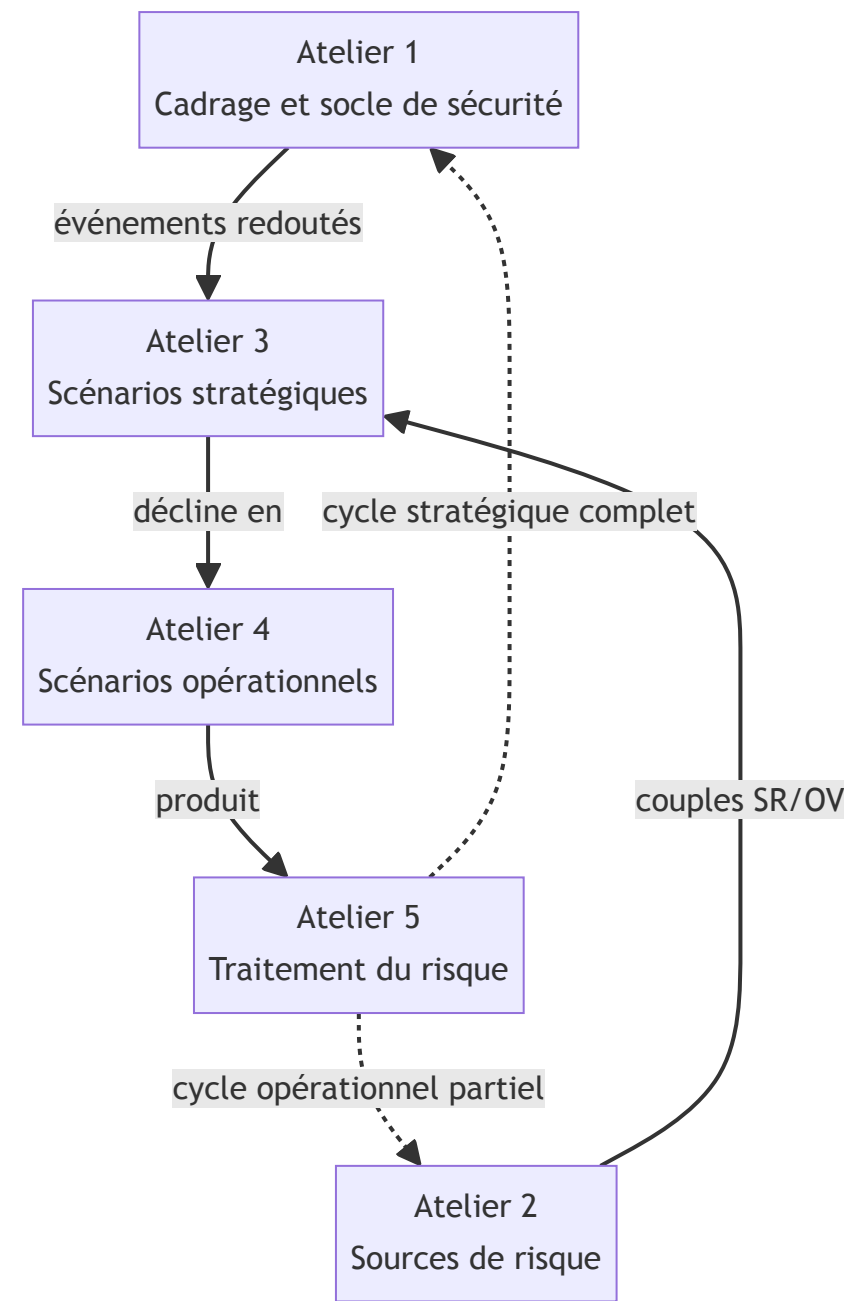
Fixer l'ordre de lecture avant le détail : quel atelier alimente lequel.

NIVEAU D'ABSTRACTION

Repère — 5 boîtes, pas de classes.

REPRÉSENTÉ

Le flux réel : les ateliers 1 et 2 alimentent tous deux l'atelier 3, qui se décline ensuite en 4 puis 5.



La méthode EBIOS RM est explicitement itérative, pas un pipeline à sens unique : l'atelier 5 rouvre soit un cycle stratégique complet (retour à l'atelier 1), soit un cycle opérationnel partiel (retour à l'atelier 2) — flèches pointillées.

02b **Diagramme de classes — modèle de domaine, en détail**

OBJECTIF

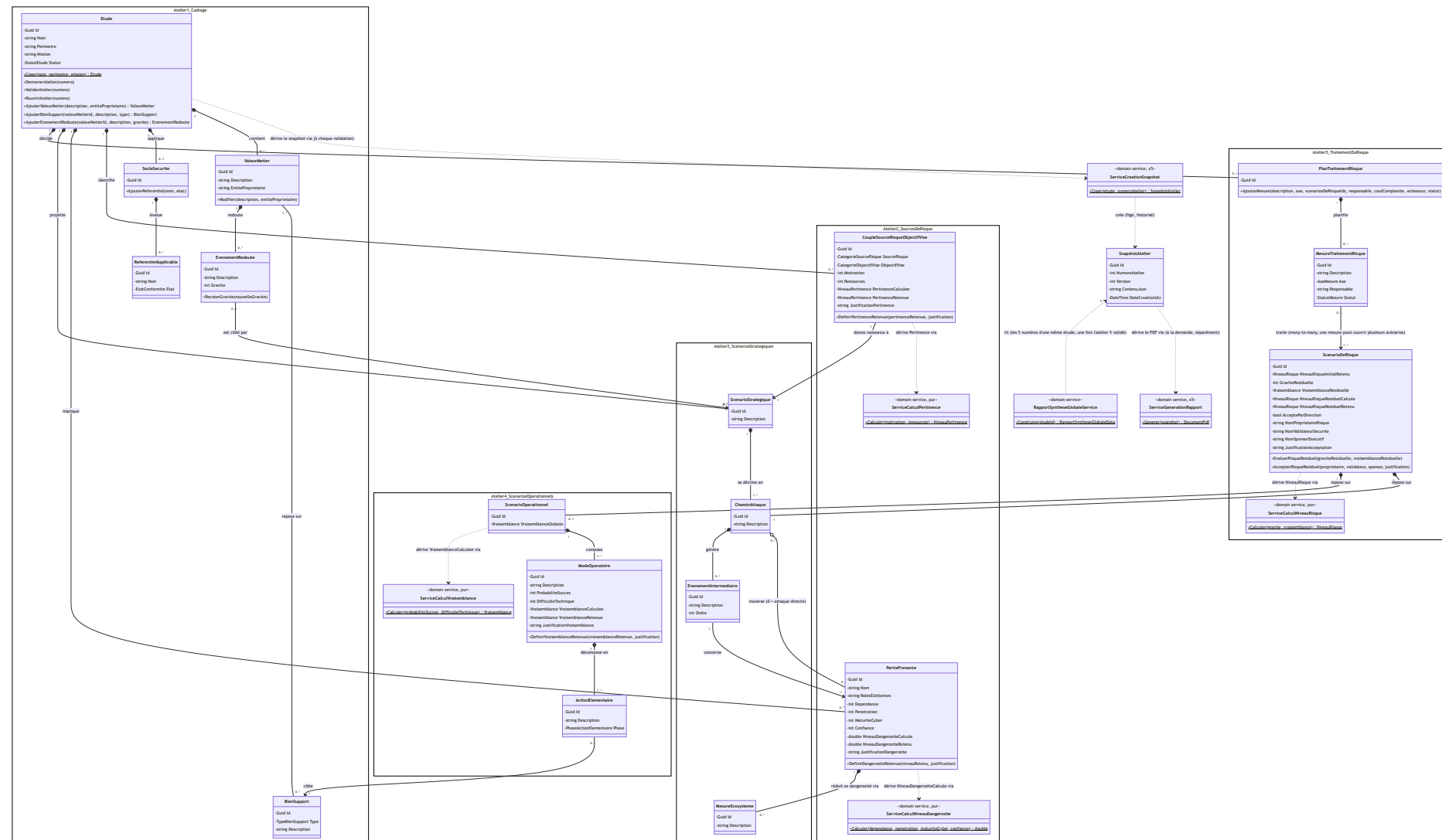
Le modèle métier complet de la méthode EBIOS RM (ANSSI) — pas les tables PostgreSQL.

NIVEAU D'ABSTRACTION

Domaine (Core Engine). Vocabulaire entièrement en français.

REPRÉSENTÉ

L'agrégat Etude et ses entités enfants pour les 5 ateliers, groupés par namespace, avec

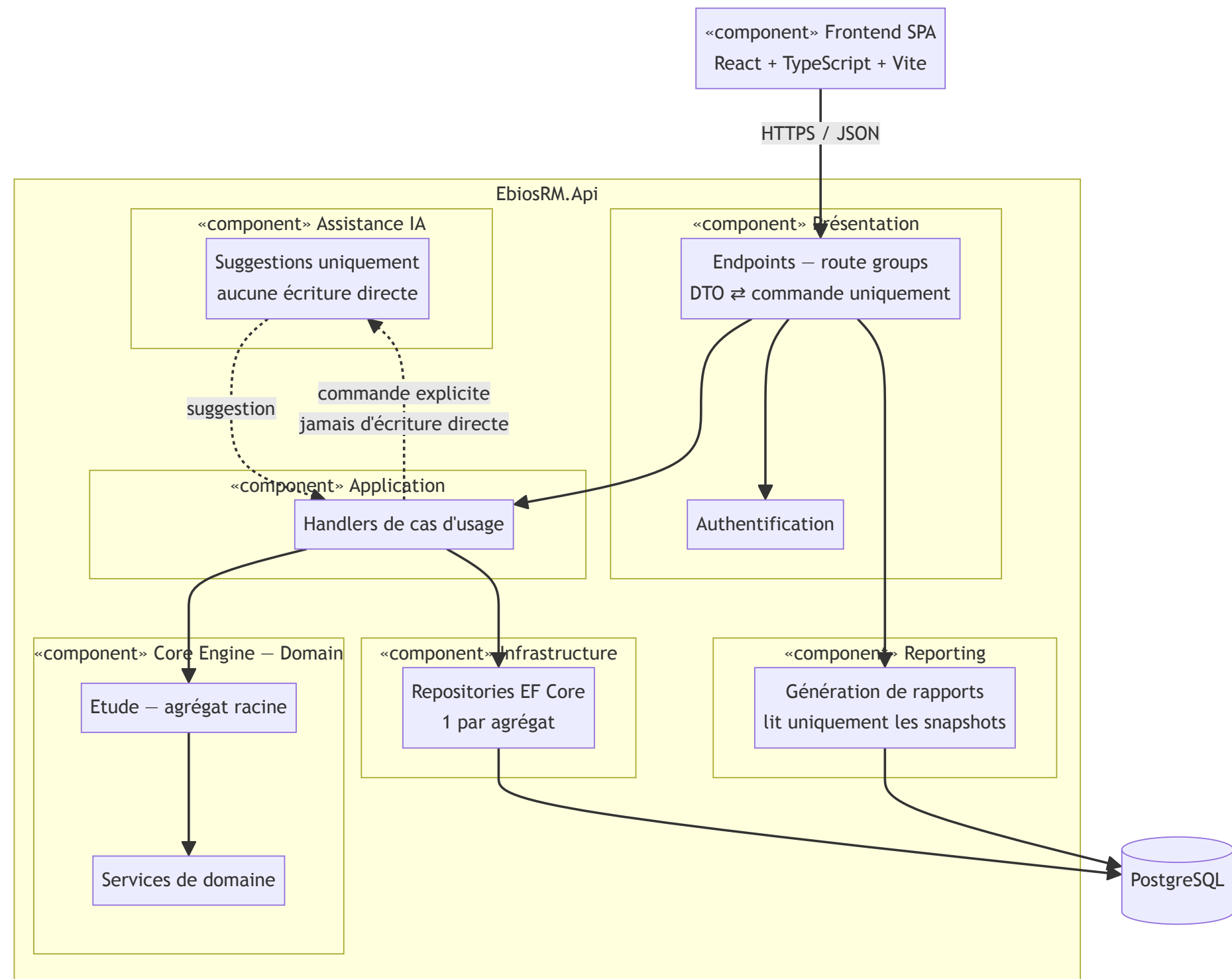


Le fil rouge méthodologique, vérifié contre la documentation officielle : un **CoupleSourceRisqueObjectifVise** (atelier 2) donne naissance à exactement un **ScenarioStrategique** (atelier 3, cardinalité bijective confirmée), qui se décline en un ou plusieurs **CheminAttaque** — chacun traversant zéro, une, ou plusieurs **PartiePrenante** de l'écosystème (zéro = attaque directe) et générant un **EvenementIntermediaire** à chaque tiers traversé. La **Gravite** n'est jamais dupliquée sur **ScenarioStrategique** : elle reste portée par l' **EvenementRedoute** ciblé (atelier 1) et lue en direct — même principe pour **ScenarioDeRisque**, dont le niveau de risque *initial* n'est jamais stocké (il se dérive à la volée de cette **Gravite** et de la **Vraisemblance** du **ScenarioOperationnel**). Un **CheminAttaque** et son **ScenarioOperationnel** associé (atelier 4) forment ensemble ce même **ScenarioDeRisque** (atelier 5) — pas deux classes reliées en cascade. Le risque *résiduel*, en revanche, exige une nouvelle saisie de l'analyste (**Gravite** et **Vraisemblance** résiduelles, après application des

mesures), d'où les attributs stockés sur cette classe. Chaque `MesureTraitementRisque` du `PlanTraitementRisque` (terme officiel depuis EBIOS RM 1.5, remplace "PACS", structuré en 4 axes officiels : Gouvernance, Protection, Défense, Résilience) porte un `Responsable` — qui exécute la mesure, un rôle distinct du `EntiteProprietaire` d'un actif (atelier 1) ou du propriétaire d'un risque (ci-dessous) — et peut couvrir plusieurs scénarios de risque à la fois (many-to-many). L'acceptation du risque résiduel par la Direction est formalisée directement sur `ScenarioDeRisque` (propriétaire du risque, validateur sécurité, et — uniquement si le résiduel reste Élevé — sponsor exécutif nommé et justification écrite, conformément à ISO/CEI 27005:2022). Chaque valeur dérivée (Pertinence, NiveauDangerosite, Vraisemblance, NiveauRisque) est calculée par un service de domaine dédié -- jamais saisie directement, mais l'analyste peut retenir une valeur différente avec justification obligatoire (jugement d'expert), sans jamais écraser la valeur calculée. Un `SnapshotAtelier` fige chaque validation d'atelier et sert de source unique au `ServiceGenerationRapport` de son atelier — c'est ce que montre en détail le diagramme de séquence — et, une fois les 5 ateliers validés, au `RapportSyntheseGlobaleService` qui consolide les 5 snapshots d'une même étude dans le document remis à la Direction.

03 **Diagramme de composants**

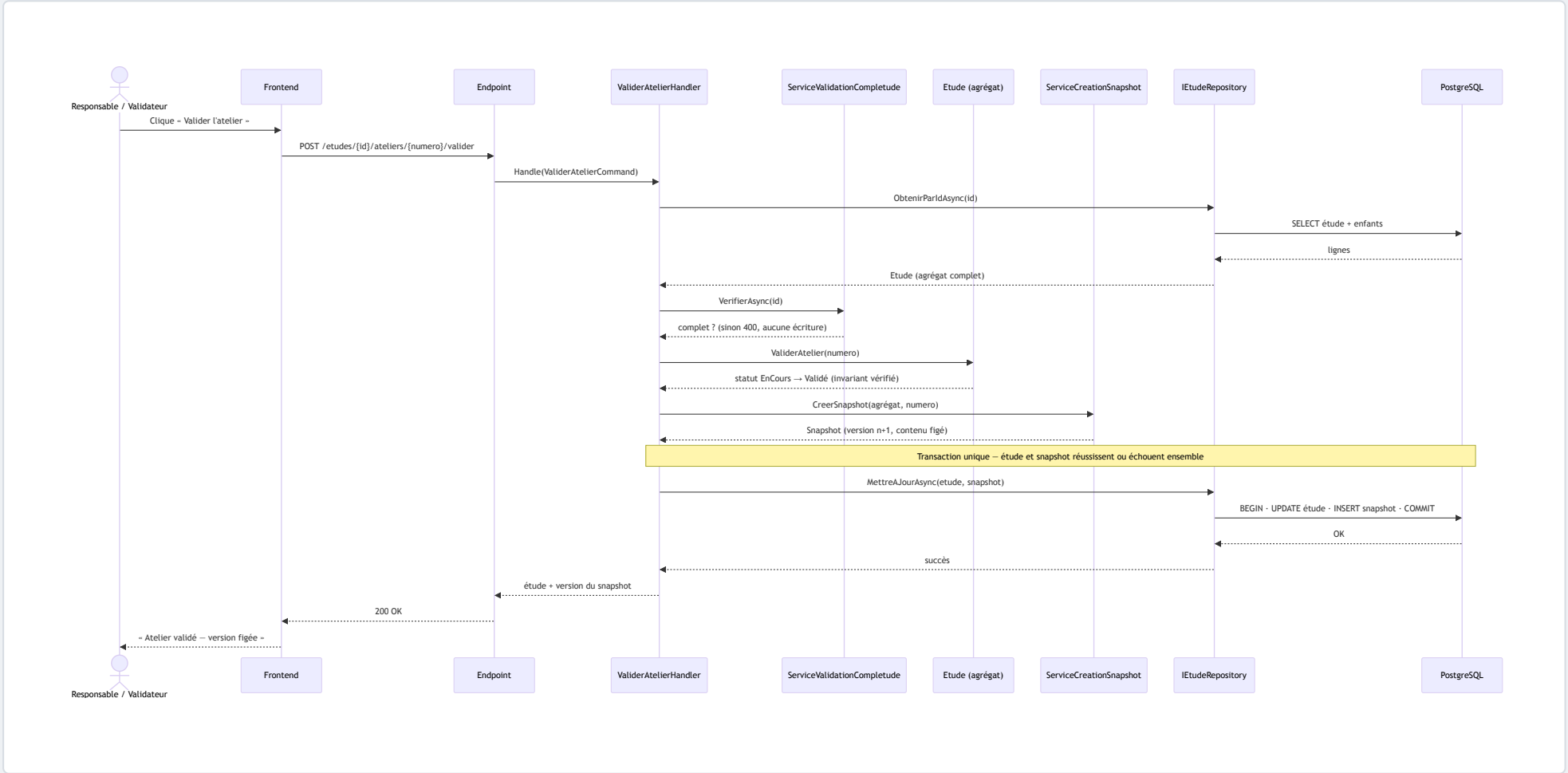
OBJECTIF	NIVEAU D'ABSTRACTION	REPRÉSENTÉ	EXCLU VOLONTAIREMENT
Comment le logiciel est découpé en morceaux, et qui a le droit de parler à qui.	Architecture logicielle — indépendant du déploiement physique (diagramme 06).	Frontend, Présentation, Application, Core Engine, Infrastructure, Reporting, Assistance IA.	Reverse proxy, cache, observabilité — hors du périmètre logiciel, traités dans le diagramme de déploiement.



Le composant Assistance IA ne parle qu'à l'Application, via les mêmes commandes qu'un utilisateur humain — jamais directement au Domain ni à la base. C'est une frontière architecturale, pas une option de configuration : aucun chemin d'écriture ne contourne l'Application.

04 Diagramme de séquence — validation d'un atelier

OBJECTIF	NIVEAU D'ABSTRACTION	REPRÉSENTÉ	EXCLU VOLONTAIREMENT
Montrer, étape par étape, le flux le plus critique du produit : valider un atelier et figer son livrable.	Applicatif — un cas d'usage précis, de bout en bout.	Le contrôle de complétude préalable, puis la validation et la création du snapshot dans une seule transaction.	Les autres séquences (création d'étude, saisie, rapport, suggestion IA) — un diagramme par flux critique pour rester lisible ; celui-ci illustre le schéma applicatif commun aux 5 ateliers.



La transaction unique garantit qu'il ne peut jamais exister d'atelier au statut « Validé » sans son snapshot associé — l'invariant est structural, pas laissé à la discipline de l'appelant.

05 Diagrammes d'états — cycles de vie

OBJECTIF

Les transitions autorisées, à trois échelles : un atelier, l'étude entière, et une mesure du plan de traitement du risque.

NIVEAU D'ABSTRACTION

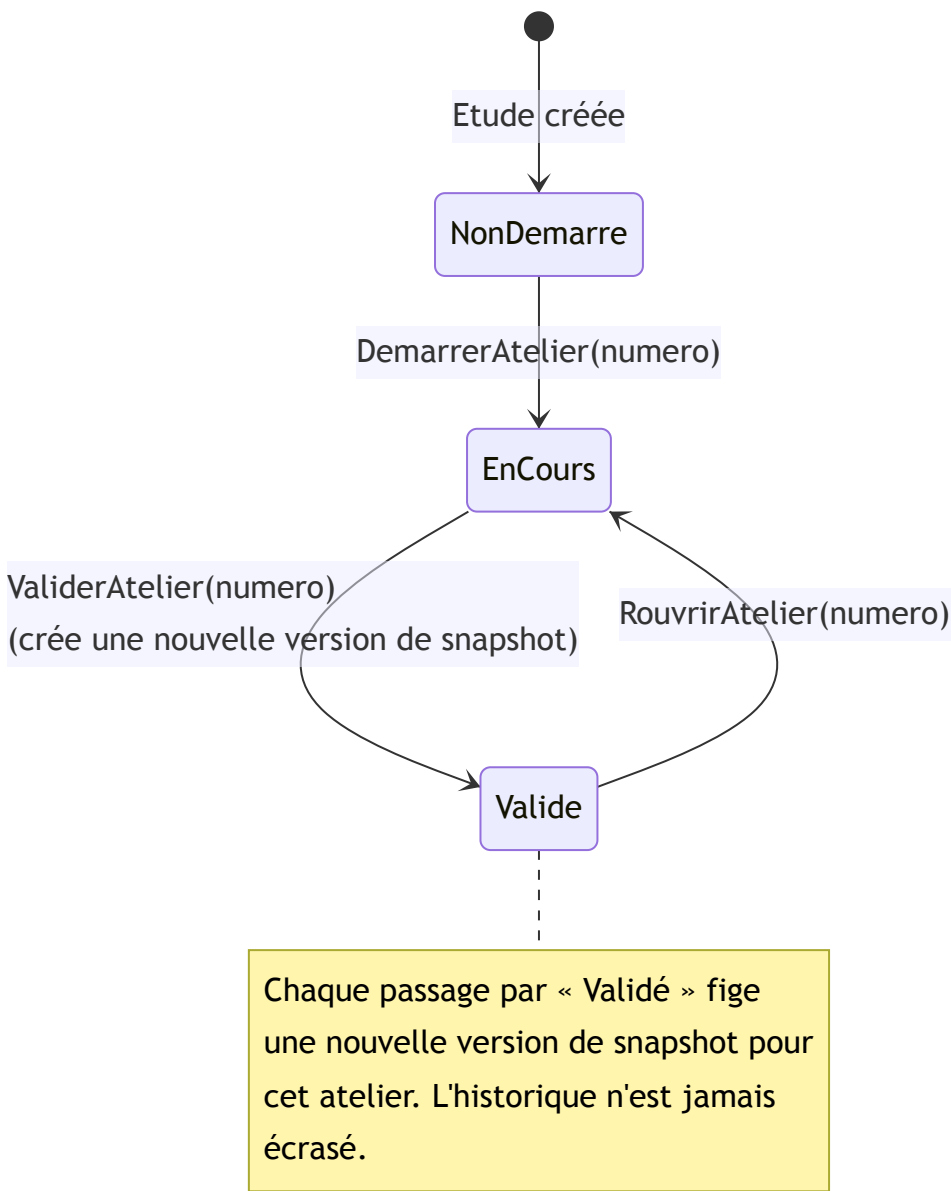
Domaine — trois machines à états complémentaires.

REPRÉSENTÉ

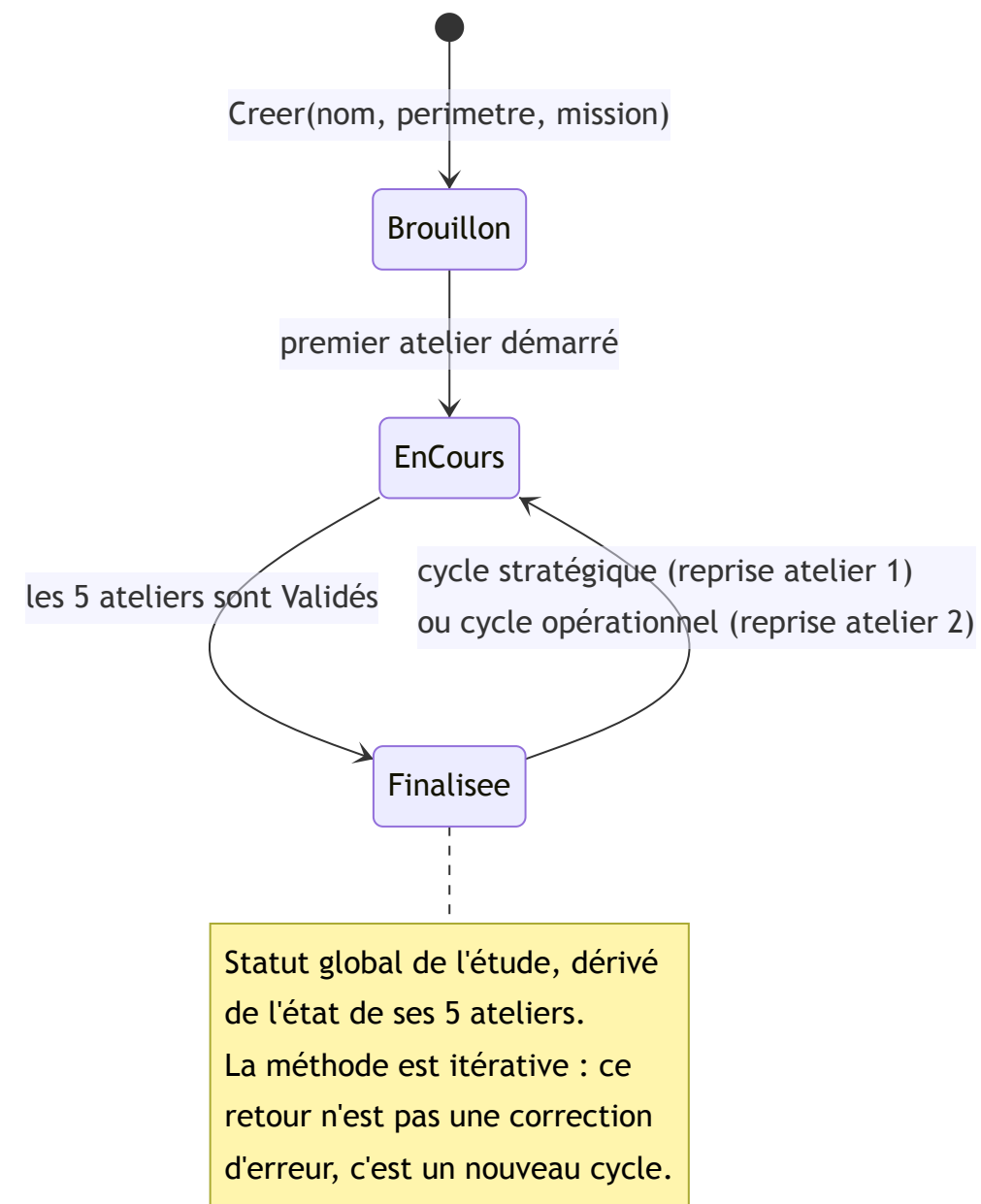
Le cycle générique d'un atelier ; le statut global de l'étude, itératif ; le suivi individuel d'une mesure du plan de traitement du risque (statuts officiels).

EXCLU VOLONTAIREMENT

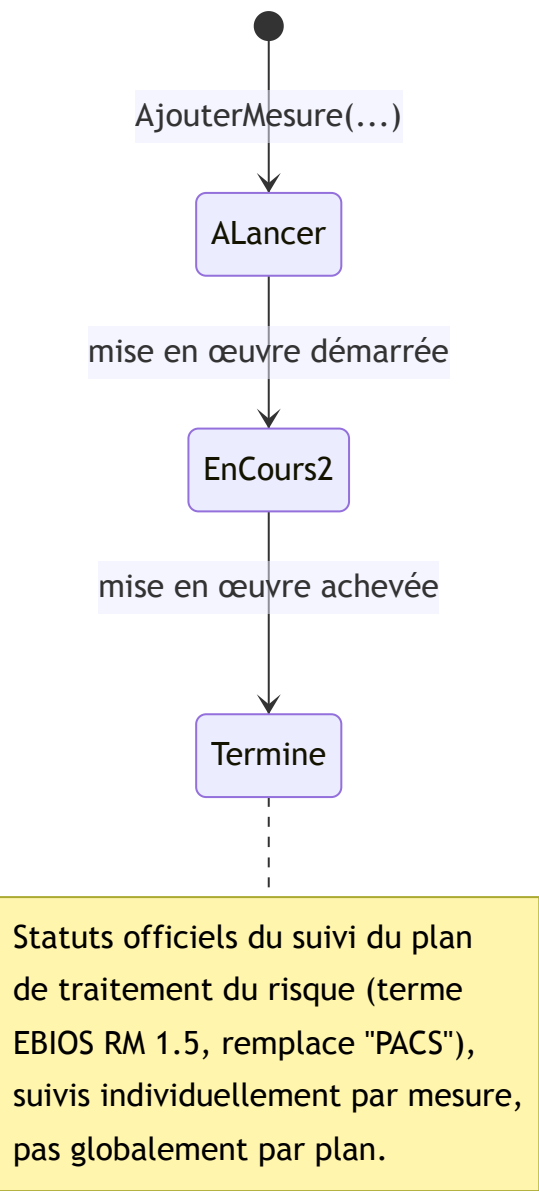
Les 5 machines à états d'atelier déroulées séparément — toutes des instances du même cycle générique.



Cycle applicable identiquement aux 5 ateliers — chacun progresse indépendamment des autres.



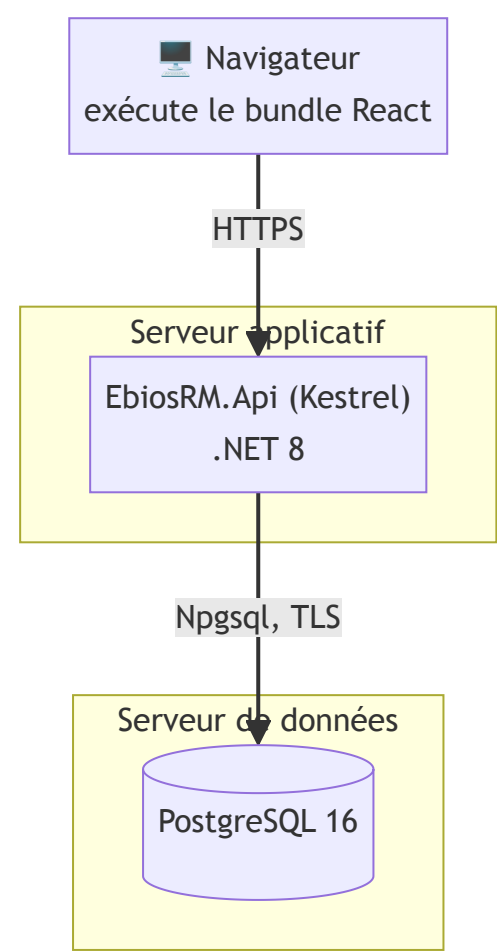
Le statut de l'étude n'est jamais modifié directement : il se recalcule à partir du statut de ses 5 ateliers.



« À lancer / En cours / Terminé » — les trois statuts réels utilisés dans le tableau de suivi du plan de traitement du risque de la documentation officielle.

06 Diagramme de déploiement

L'infrastructure physique/logique qui exécute la plateforme.	Infrastructure — nœuds et protocoles entre eux.	Navigateur, instance API, PostgreSQL.	Reverse proxy, cache, broker de messages — la charge d'une seule organisation par déploiement ne les justifie pas ; le Domain et le schéma PostgreSQL restent inchangés si on les ajoute.
--	---	---------------------------------------	---



Le Domain et le schéma PostgreSQL sont indépendants de leur topologie de déploiement : ajouter un reverse proxy devant plusieurs instances API ne demande aucune modification du Core Engine.

